

SECURITY AUDIT REPORT

MBR Cookie Consent

WordPress plugin — version 2.3.0

Audit carried out by

Claude (claude.ai)

an AI assistant made by Anthropic

OUTCOME

All findings resolved in version 2.3.1

No evidence of exploitation was found. All issues were identified by code review.

Plugin author

Robert Palmer — Made by Robert / Little Web Shack

Date of audit

30 July 2026

Static source code review — not a penetration test or certification

At a glance

A plain-English summary for site owners using this plugin.

MBR Cookie Consent version 2.3.0 was reviewed line by line for security problems. The review found eleven security issues and seven reliability issues that affected how reliably the plugin did its job. Every one of them has been fixed in version 2.3.1, which is available now.

None of the issues were being exploited, and none of them exposed passwords, customer records or payment data. The plugin does not store any of those. The most significant problems concerned two things: whether a visitor could influence which privacy rules they were shown, and whether your consent log could be filled with junk entries by an outsider.

What was found

Severity	Count	What this level means	Status
MEDIUM	4	Worth fixing promptly. Could affect the accuracy of your compliance records, or let a visitor influence which privacy rules applied to them.	All fixed
LOW	7	Limited practical impact, or only reachable by someone who already has administrator access to your site.	6 fixed, 1 reviewed and accepted
RELIABILITY	7	Not security problems, but faults that made the plugin behave incorrectly — including two that affected cookie blocking and consent sharing.	All fixed

No critical or high severity issues were found. Nothing discovered would have allowed an outsider to take control of a website, read its database, or run their own code on it.

The two findings that mattered most

1. A visitor could influence which privacy rules they were shown. If you had automatic location detection switched on, the plugin worked out a visitor's country partly from information the visitor's own browser supplied. That information can be faked. In practice this meant a determined visitor could present themselves as being somewhere with weaker privacy rules. It also allowed someone to generate a very large number of location lookups, which could slow a site down. Version 2.3.1 only accepts that information when the request provably came through a recognised network provider such as Cloudflare.
2. Blocked tracking scripts could fail to switch back on. This one is not a security hole but it is the finding most likely to have affected a real site. Because of a single missing word in the code, scripts blocked by their web address were not correctly labelled with their cookie category. After a visitor pressed Accept, those scripts could silently fail to start. Analytics or advertising tags may therefore have been missing data even where consent had been given. Blocked embedded content, such as videos, was not affected.

What you should do

Five practical steps, in order of importance.

Step 1 — Update to version 2.3.1

This is the only step that is strictly necessary. Every issue in this report is fixed in 2.3.1. The update appears in your WordPress Plugins screen in the normal way. Your settings, your consent log and your banner design are all preserved.

Step 2 — If you use A/B testing, reset your statistics

The plugin was counting a banner impression every time a page loaded, rather than once per visitor. A single person refreshing a page inflated the count each time. Your existing figures are therefore overstated, and not overstated evenly across the variants being tested — so the variant that looks like it is winning may not be. If you are using this feature, reset the statistics after updating and start the comparison again. If you do not use A/B testing, ignore this step.

Step 3 — Check for a notice about location lookups

The service the plugin used by default to look up visitor locations, ip-api.com, only offers an encrypted connection to paying customers. Sending these lookups unencrypted is not acceptable in a privacy plugin, so sites using it without a paid key have been moved automatically to a different free service, ipapi.co, which is encrypted. If this affects you, a dismissible notice will appear in your WordPress admin explaining it. The new service allows 1,000 lookups a day, which is ample for most sites because results are cached for 24 hours. A very busy site may prefer to add an ip-api.com paid key instead.

Step 4 — If you share consent across subdomains, test it

Consent sharing between subdomains was broken for every domain ending in .co.uk, and for similar endings such as .com.au and .co.nz. The plugin calculated the wrong domain for the cookie, and browsers silently rejected it. If you rely on this feature on such a domain, it has not been working. After updating, confirm that accepting cookies on one subdomain now carries across to the others.

Step 5 — On multisite, re-check your network button labels

On WordPress multisite, the network-level text for the Accept, Reject and Customise buttons was being saved incorrectly — stored as the number 1 instead of the words you typed. If your network settings show 1 where button text should be, re-enter the labels and save.

Do I need to tell anyone, or notify a regulator?

Almost certainly not. A personal data breach notification is generally required when personal data has actually been exposed or lost. Nothing in this report indicates that happened, no exploitation was found, and the issues were identified by proactive review rather than by an incident. This report is provided for your records and for your own due diligence file. If you are in a regulated sector or have specific concerns, take your own legal advice — nothing here is legal advice.

Scope and method

What was examined, how, and — importantly — what this report does not cover.

What was examined

The complete source code of MBR Cookie Consent version 2.3.0: approximately 13,400 lines of PHP across 30 files, plus the plugin's JavaScript. Every point where the plugin accepts information from outside — web forms, background requests, cookies, browser headers and uploaded files — was traced through to where that information is stored or displayed.

How it was examined

- Every administrative action was checked for both a permission check and an anti-forgery token, so one administrator cannot be tricked into performing an action by visiting a malicious page.
- Every database query was checked for SQL injection — the flaw that lets an attacker read or alter a site's database.
- Every place stored information is displayed was checked for cross-site scripting — the flaw that lets an attacker's code run in another person's browser.
- All requests the plugin makes to outside services were checked for encryption and certificate validation.
- All code was syntax-checked against PHP 8.3, and fixes were unit-tested: 54 test cases covering network address matching, domain calculation and the handling of faked browser headers.

Limitations — please read

This is a code review, not a certification

This report is the result of reading and analysing source code. It is not a penetration test, a formal security certification, and not an accredited third-party audit. It carries no warranty or guarantee.

Specifically, the following were not covered:

- Live testing. No running website was tested. Problems that appear only at runtime, or in combination with particular hosting, could exist and would not be visible here.
- Third-party library code. The plugin bundles Plugin Update Checker, an established open-source library by Yahnis Elsts. It was confirmed to be a current, unmodified version, but its internals were not audited.
- WordPress itself, your theme, your other plugins and your hosting. These are usually where a site's real risk sits. A secure plugin on an out-of-date install is still an insecure website.
- Legal compliance. This is a technical security review. It makes no assessment of whether your use of this plugin makes you compliant with GDPR, UK DUAA, CCPA or any other privacy law. That depends on your configuration and your circumstances, and is a question for a qualified adviser.

Finally, and importantly: finding no further issues is not proof that none exist. Any review, human or automated, can miss things. This report describes what was found, not everything that could ever be found.

Security findings

Eleven findings, each with its practical effect and current status.

Medium severity

#	Finding	What it meant in practice	Level
1	Visitor location headers were trusted without verification	A visitor could fake the information used to determine their country, and so be shown the privacy rules of a different region. The same weakness let an outsider generate unlimited location lookups and cache entries, which could slow a site down.	MEDIUM
2	Location lookups were sent unencrypted	The default lookup service was contacted over an unencrypted connection. Anyone able to observe that connection could change the country returned, silently altering which privacy rules a visitor received. Visitor IP addresses also travelled to a third party unencrypted.	MEDIUM
3	The consent log could be flooded by an outsider	The address that records consent has to accept unauthenticated requests, for good technical reasons to do with page caching. It had no rate limit, so anyone could add unlimited entries to the consent log — the very record you would rely on to demonstrate compliance.	MEDIUM
4	Exported logs could carry spreadsheet formulas	Consent categories submitted by visitors were written into the CSV export unaltered. Excel and similar programs treat certain values as live formulas, so a malicious entry could execute when an administrator opened the exported file.	MEDIUM

Security findings, continued

Lower severity findings. Several of these require administrator access to reach at all.

#	Finding	What it meant in practice	Level
5	A/B test tracking had no rate limit	The tracking addresses accepted unlimited unauthenticated requests, so a third party could distort the results of a test.	LOW
6	Blocked scripts were restored using eval()	A programming technique that is blocked by strict browser security policies. On sites using such a policy, cookie blocking would not work correctly.	LOW
7	The consent cookie was not marked as secure	On encrypted sites the consent cookie could still be sent unencrypted in some circumstances, where it could be read or altered in transit.	LOW
8	The cookie scanner could fetch any web address	An administrator could point the scanner at an address on the hosting provider's internal network. Requires administrator access, so the practical risk was small.	LOW
9	The site address was read from the visitor's request	Used to calculate the consent cookie's domain. A faked value combined with page caching could have stopped consent saving correctly for everyone.	LOW
10	The settings save accepted unrecognised entries	Any setting name was accepted and written to the database. Requires administrator access. It also meant a stray database entry was created every time settings were saved.	LOW
11	Custom CSS is not fully restricted	Custom styling can reference external addresses. Reviewed and deliberately left unchanged: the feature is available only to full administrators, who can already add code to a WordPress site by design.	NO CHANGE

Findings 1 to 10 are fixed in version 2.3.1. Finding 11 was assessed and no change was made, for the reason stated.

Reliability findings

Faults that were not security problems, but that stopped the plugin working as intended.

#	Finding	What it meant in practice	Level
1 2	Blocked scripts lost their cookie category	A missing word in the code left scripts blocked by web address without a category label. After a visitor accepted cookies, those scripts could silently fail to start, so analytics and advertising tags may have missed data even where consent was given. Blocked embedded content such as videos was unaffected.	RELIABILITY
1 3	Subdomain consent sharing failed on .co.uk and similar domains	The plugin calculated the cookie domain as “co.uk” rather than “example.co.uk”. Browsers reject this, so consent never carried between subdomains. Affected all of .co.uk, .com.au, .co.nz and similar endings.	RELIABILITY
1 4	A/B impressions were counted per page load	One visitor refreshing a page was counted repeatedly, inflating results unevenly across variants.	RELIABILITY
1 5	Multisite button labels were saved as numbers	Network-level Accept, Reject and Customise button text was stored as 1 instead of the words entered.	RELIABILITY
1 6	Some settings were missing from export files	The AI training disclosure settings and the location cache duration were silently omitted when exporting settings to move to another site.	RELIABILITY
1 7	Upgrade notices were never displayed	A previous version recorded that it had preserved a site's settings and intended to say so, but nothing ever showed the message.	RELIABILITY
1 8	Private network addresses were detected incompletely	Certain internal network ranges were not recognised, causing unnecessary external lookups for visitors on those networks.	RELIABILITY

All reliability findings are fixed in version 2.3.1.

What was found to be sound

A security report naturally dwells on problems. These areas were examined and found to be correctly built.

Area examined	Result
Database queries	No SQL injection was found anywhere. All queries correctly separate instructions from data, and the one place where a sort order must be inserted directly uses a fixed list of permitted values.
Displayed information	No cross-site scripting was found. Every place the plugin displays stored information escapes it correctly, including the consent log and all administration screens.
Administrator permissions	Every one of the plugin's twenty administrative actions requires both the correct permission level and a valid anti-forgery token. No gaps were found — this is an area where plugins commonly fall short.
Dangerous PHP functions	None of the functions commonly associated with serious vulnerabilities were present anywhere in the plugin's PHP code.
Settings import	The import feature, which handles an uploaded file, was found to be carefully built: it validates the upload, limits its size, permits only recognised settings, and keeps a backup so an import can be undone.
Direct file access	Every file correctly refuses to run if accessed directly, rather than through WordPress.
Privacy of the consent log	IP addresses are shortened before storage so individuals cannot be identified from the log. The review strengthened this further for IPv6 addresses, where the previous shortening left enough of the address to identify a household.
Update mechanism	Updates are delivered over an encrypted connection from a fixed, publisher-controlled address. The bundled update library is a current, unmodified release.

A note on what this plugin stores

MBR Cookie Consent stores consent records: the date and time, a shortened IP address, the categories accepted, and the method used. It does not store passwords, payment details, customer records or contact information. It sends no analytics or telemetry to its author. This limits how much harm any flaw in it could cause, and it is the main reason no finding in this report reached critical or high severity.

Conclusion

Overall assessment and formal statement.

MBR Cookie Consent version 2.3.0 was found to be a competently built plugin. The areas where WordPress plugins most often fail — database queries, displayed output, and administrator permission checks — were handled correctly and consistently throughout, with no gaps. That is not a given, and it reflects well on the code.

The weaknesses that were found clustered in one place: the parts of the plugin that must accept requests from ordinary visitors rather than from logged-in administrators. This is a genuinely difficult area for a consent plugin, because the usual protection — an anti-forgery token — cannot be relied upon when pages are served from a cache. The original code made a reasonable engineering judgement there, but did not add the rate limiting that judgement then required. Version 2.3.1 adds it.

The single most consequential finding was not a security hole at all, but a one-word omission that could stop blocked scripts from restarting after consent was given. It is a reminder that in a consent plugin, correctness and compliance are the same thing: a script that fails to run after consent is a fault, and a script that runs before consent is a breach.

With version 2.3.1 installed, no outstanding security issues from this review remain.

Statement of authorship

This audit was carried out by Claude (claude.ai), an AI assistant made by Anthropic, at the request of the plugin's author. The review consisted of a complete static analysis of the plugin's source code, together with targeted unit testing of the code written to remedy the findings.

Readers should weigh this accordingly. An AI-conducted code review is a useful and thorough form of scrutiny, and it examined every line of the plugin. It is not equivalent to an accredited third-party security audit or a penetration test, and it should not be presented as one. It carries no warranty, guarantee or certification, and it does not constitute legal advice.

Software audited	MBR Cookie Consent for WordPress, version 2.3.0
Remediated in	Version 2.3.1
Code reviewed	Approximately 13,400 lines of PHP across 30 files, plus JavaScript. Bundled third-party library excluded.
Method	Static source code analysis; PHP 8.3 syntax verification; unit testing of remediation logic
Auditor	Claude (claude.ai), an AI assistant made by Anthropic
Date	30 July 2026
Plugin author	Robert Palmer — Made by Robert / Little Web Shack (littlewebshack.com)

This document may be shared and retained for due diligence purposes. It describes version 2.3.0 as reviewed on 30 July 2026 and does not describe any later version.